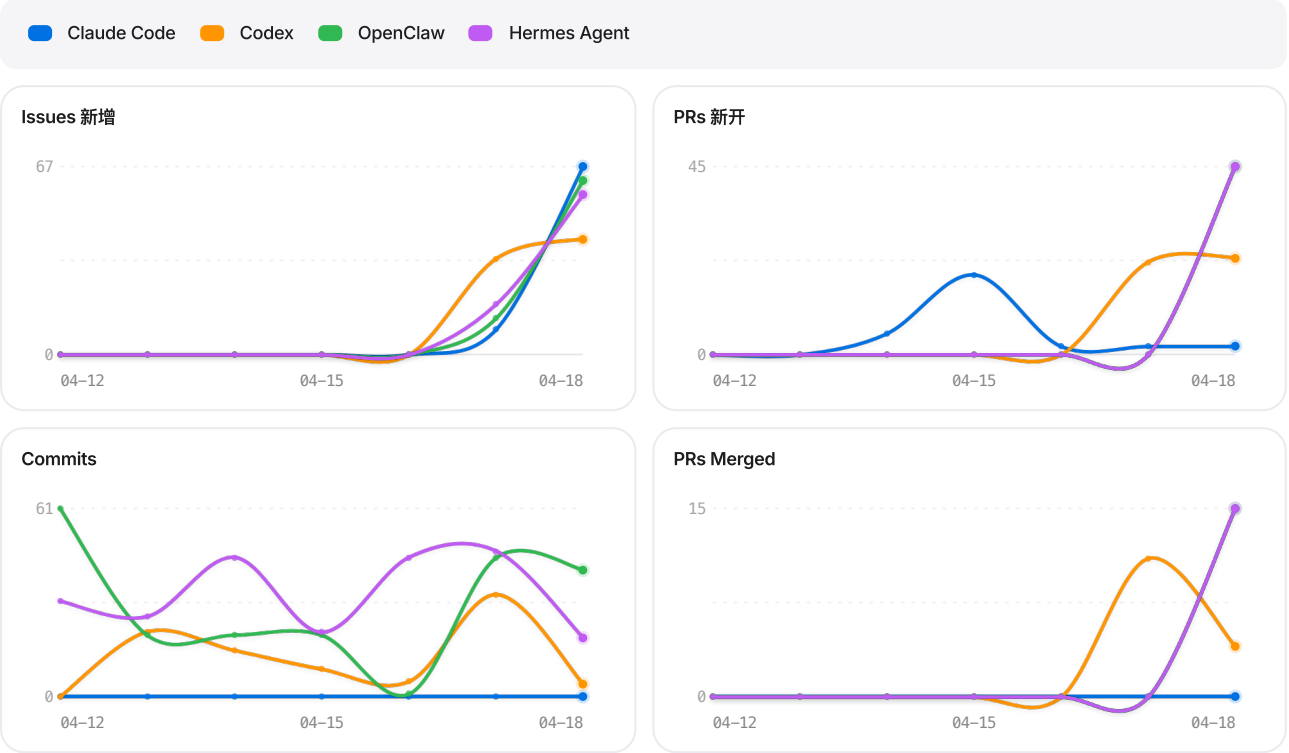
辛哥的开源风向

GitHub Daily · 2026-04-19

今日头条

今天最值得停下来看的信号横跨两个项目：Claude Code 同一天暴露了两个安全问题——claude-in-chrome MCP 可以无提示跨账号接管他人浏览器会话，文件历史快照功能会把 .env 私钥明文留在本地隐藏目录；Hermes Agent 当天就把 Claude Code 2.1.113 引入的危险命令检测规则（含 macOS `/private/` 路径绕过）移植进来。两件事拼在一起是一个不寻常的跨项目安全信号。如果你在用 Claude Code 的文件历史或 chrome MCP，今天先查清楚再说。

AI Agent 标杆项目动态



Claude Code

今日 Claude Code 的主线分两条，互不干扰。

技术侧：v2.1.113 把执行层从 JavaScript 包切换为原生二进制，Nix、Guix 等非标准 Linux 发行版因 ELF 解释器路径问题立即触发兼容性回归；v2.1.114 当天跟上热修复，顺带修了 Agent Teams 权限对话框崩溃。从发版到回归再到热修复不超过一个工作日，节奏快，代价是非主流发行版用户当了试验田。Nix/Guix 用户目前建议锁定 v2.1.114。

安全侧：两个问题同时浮出水面。其一，claude-in-chrome MCP 可在无任何提示的情况下操控他人账号的浏览器，跨账号权限边界没有守住；其二，文件历史快照会将 .env 等文件的明文内容留存在本地隐藏目录，私钥暴露路径比多数人意识到的要短。官方尚无公开说明，chrome MCP 先关掉比较稳。另有多 agent 并发场景下的父会话死锁，有完整复现路径，待修。

Codex

今日 Codex 最集中的工程量落在设备密钥基础设施上。四个关联 PR 一次性提交了协议定义、核心 crate、app-server 适配层，以及 macOS（Secure Enclave）、Windows（CNG/TPM）、Linux（TPM2）三套平台实现，意图是为本地设备绑定认证提供硬件级支撑——换句话说，Codex 在给"这台机器 = 这个用户"这个等式打地基。

配套动作：MCP 工具的权限 hook 把原有 Bash hook 的 payload 结构延伸进来；Plan Mode 新增"清空上下文后实现"路径，让规划对话和实现线程彻底解耦，不用把整段讨论带进生成阶段。24 小时内连发 alpha.8/9/10 三个预发布，团队显然处于密集冲刺。

OpenClaw

今日 OpenClaw 最值得标记的是一个高危稳定性 bug 的处置速度：weixin 插件 sidecar 进程误杀父级 gateway、触发无限重启循环的问题当天提、当天合入，修法是在 stale-pid 清理逻辑里把整条祖先 PID 链排除在外。cron 任务超时后遗留幽灵 task 行（生产环境有 29 个 stale_running 实例作为证据）也在排队等合。

功能侧有一个还在评审的大 PR：lab 实验性 prompt 覆盖层，支持 model-specific AGENTS.md addenda，首批含 GPT-5.4 调参包；同作者配套提交了 NO_REPLY 策略按会话类型分级控制。当前影响面最宽的未修问题是 OpenRouter base URL 被硬编码为 `/v1` 而非正确的 `/api/v1`，导致所有模型调用静默失败——用 OpenRouter 的先确认版本再说。

Hermes Agent

今日 Hermes Agent 的动作方向最清晰：基础设施可靠性是主线，功能扩展是副线，两条并跑。

可靠性侧：流式传输中途 stall 导致工具调用丢失不再静默退出；Signal typing 指标的无限重试被替换为指数退避；Telegram session 槽位的竞态 bug 当天报告、当天提 PR。另有一支分支明确标注"灵感来自 Claude Code 2.1.113"，把 macOS `/private/` 路径绕过等三条危险命令检测规则移植进来——说明 Hermes 团队在主动跟踪 Claude Code 的安全修订，这个习惯比多数 agent 项目认真。

功能侧两个主动架构决策：新增 `/steer` 指令，允许用户在 agent 运行期间于下一次工具调用结束后注入引导文本，不中断流程也不破坏 prompt cache；`execute_code` 默认模式从隔离临时目录切换为 project 模式，与 `terminal()` 共用相同 CWD 和解释器，直接针对弱模型反复混淆工作目录的问题——代价是执行隔离性降低，适不适合你的场景要自己判断。

GitHub 开源社区风向

Daily Trending Top 1

Daily #1 thunderbird/**thunderbolt**

★ 1.4k | +458 / 日 | monorepo 10万行 | Tauri 2 全端 | PowerSync + Bun/Elysia | 后量子 E2EE

Mozilla Thunderbird 团队开源的跨端 AI 客户端，桌面（Mac/Linux/Windows）+ 移动（iOS/Android）+ Web 同一套代码，主打自托管、模型可替换、数据自持，面向企业私有化部署场景。

> 一句话 Mozilla 出手的自托管 AI 客户端，工程底子扎实、全栈完整，但 0.1.x 阶段、自托管门槛高。

Weekly Trending Top 10

#1 multica-ai/**andrej-karpathy-skills**

★ 57.2k | +42,267 / 周 | 纯文档单 Skill | Markdown | Claude Code Plugin | Karpathy 推文改编

把 Karpathy 那条关于 LLM 写代码常见毛病的推文，拆成四条行为准则，打包成 Claude Code 插件、Cursor 规则和可直接下载的 CLAUDE.md，给使用 AI 编程助手的开发者用。

> 一句话 把一条推文包装成三种 IDE 配置，内容薄但切实可复用，适合直接抄进自己的 CLAUDE.md。

#2 NousResearch/**hermes-agent**

★ 98.9k | +47,053 / 周 | 大型单体 45 万行 | Python 多厂商 agent | 15+ IM 平台网关 | Nous Research

Nous Research 出品的自托管 AI agent 框架，一个 Python 进程接入十几种 IM（Telegram/Discord/Slack/飞书/钉钉/微信 等）与几十种 LLM 后端，自带 skills 体系、cron、RL 训练挂钩。

> 一句话 Nous Research 把 agent 做成"跑在 VPS 上、从手机 IM 调"的产品形态，工程体量大、覆盖面惊人，但核心文件过胖、"自我进化"是包装词。

#3 shiyu-coder/**Kronos**

★ 19.2k | +6,511 / 周 | 中型研究代码库 | PyTorch | 金融 K 线基础模型 | AAAI 2026

Kronos 是一个面向金融 K 线（OHLCV）序列的开源基础模型家族，提供预训练权重、微调脚本和 A 股回测示例，给量化研究者和算法交易开发者做预测基线。

> 一句话 有论文有权重有微调管线的金融时序基础模型，适合量化研究者当预训练基线，不是能直接上线交易的策略。

#4 multica-ai/**multica**

★ 16.0k | +10,056 / 周 | monorepo 多栈中型 | Go + Next.js 16 | 多 CLI agent 编排 | 修改版 Apache 2.0

一个把编码 agent 当团队成员调度的 Kanban 式平台：在看板上给 Claude Code / Codex / OpenClaw / Hermes / Gemini / Cursor Agent 等 CLI 分派 issue，本地 daemon 拉代码、跑 CLI、回传进度，给多人团队用。

> 一句话 工程完整度看得出是内部产品整包开源，定位不新，但"一个看板统管八种 agent CLI"这个点对多 agent 用户确实有用。

#5 thedotmack/**claude-mem**

★ 62.2k | +14,033 / 周 | 中型多栈 monorepo | TypeScript + Bun | MCP + SQLite/Chroma | Claude Code 插件

给 Claude Code 装一套持久化记忆：通过生命周期 hook 把会话观察写入本地 SQLite + Chroma 向量库，下次会话以 MCP 工具按需检索。

> 一句话 严肃工程的 Claude Code 记忆层，架构清晰、迭代凶猛，但安装会拉起本地常驻 worker、Bun、uv、向量库，门槛不算低。

#6 microsoft/**markitdown**

★ 112k | +13,214 / 周 | 中型 monorepo ~11k 行 | Python | 20+ 格式转换器 | MCP server

微软 AutoGen 团队出品的 Python 工具库，把 PDF/Office/HTML/音图/YouTube 等常见文件统一转成 Markdown，面向 LLM 前置管线和 RAG 预处理场景。

> 一句话 LLM 文件预处理里最务实的那一类工具，结构干净、格式覆盖全，但 PDF 精度受限于传统解析器。

#7 OpenBMB/**VoxCPM**

★ 14.5k | +5,786 / 周 | 中型单包 ~10k 行 | PyTorch 2B TTS | MiniCPM-4 backbone | Diffusion Autoregressive

OpenBMB 开源的 tokenizer-free TTS 系统，最新版 VoxCPM2 是 2B 参数模型，支持 30 语种语音合成、零样本声音克隆和自然语言描述生成音色，原生输出 48kHz 采样率。

> 一句话 OpenBMB MiniCPM 团队的严肃 TTS 工作，工程完整度和开源度都够，门槛在 CUDA 12 + 8GB 显存起步。

#8 lsdefine/**GenericAgent**

★ 4.2k | +2,375 / 周 | 中型 ~8k 行 | Python | CDP 真实浏览器注入 | 多 IM Bot 前端

一个 Python 写的自主 Agent 框架，9 个原子工具让 LLM 直接驱动本地浏览器、终端、键鼠和 ADB 手机，跑过的任务沉淀为可复用 Skill。

> 一句话 野路子国产 Agent 框架，适合折腾本地自动化的玩家，不适合当严肃工程参考抄。

#9 virattt/**ai-hedge-fund**

★ 56.1k | +4,941 / 周 | 中型全栈 ~15k 行 | LangGraph 多 Agent | FastAPI + React Flow | 教育用 PoC

一个把 19 位名人投资者（巴菲特、芒格、Burry、Taleb、Cathie Wood 等）做成 LangGraph Agent、各自给出 bullish/bearish 信号、最后由组合经理综合下单的模拟交易系统，自述仅供学习，不实际下单。

> 一句话 把名人投资哲学映射成 LLM Agent 的教学玩具，工程完成度不低但离"真能赚钱"很远，作者自己已经在 v2 里推翻重做。

#10 EvoMap/**evolver**

★ 4.9k | +2,082 / 周 | 中型单体 | Node.js CLI daemon | 核心代码混淆 | GPL-3.0 声明

一个宣称"AI agent 自我进化"的 Node.js CLI daemon，循环采集运行日志触发 LLM 改代码，并通过本地 Proxy 向中心化的 evomap.ai Hub 同步"基因/胶囊/事件"资产。目标用户是

Cursor / Claude Code / OpenClaw 用户。

> 一句话 功能野心很大的"agent 自进化"框架，但核心模块已混淆、只有一条 squash commit，当前 GPL 声明下是否可审计存疑。

三类读者怎么读

- **开发者**：今天先查 Claude Code 会话目录下的隐藏文件夹，确认 .env 等敏感文件有没有被历史快照捕获；Nix/Guix 用户锁定 v2.1.114，chrome MCP 没有官方安全说明前先禁用。
- **创业者**：Codex 的硬件设备密钥基础设施和 Thunderbolt 的离线优先自托管路线指向同一个方向——把 AI 工具的数据和认证留在客户侧。这个方向有没有你的产品机会，可以拿去和几个企业客户聊聊需求强度。
- **投资者**：Hermes Agent 本周增 47k stars，RL 数据回流管线和 serverless 持久化是当前 agent 项目里少见的差异组合；但 run_agent.py 单文件一万两千行是工程硬伤，现阶段看势能信号比看代码质量更合理，实测数据出来前保持观望。